1. Alert Priority Levels

Alert Priority Levels refer to the classification of security alerts based on their severity, urgency, and potential impact on an organization's systems or data, helping SOC analysts decide which alerts must be investigated first.

In a Security Operations Center (SOC), thousands of alerts are generated daily from tools like SIEM, IDS, firewalls, and endpoint security systems. If analysts tried to investigate every alert equally, it would waste time and delay response to serious threats.
Therefore, alerts are categorized into priority levels so analysts can focus on the most dangerous threats first. Priority is determined by factors such as:

- Asset importance
- Threat severity
- Likelihood of exploitation
- Business impact

Priority Level	Meaning	Example
Critical	Immediate threat causing major damage or active compromise	Ransomware encrypting files
High	Strong indication of compromise requiring urgent investigation	Unauthorized admin login
Medium	Suspicious behavior but not confirmed malicious	Multiple failed login attempts
Low	Informational alerts with minimal risk	Single failed login

Asset Criticality

Asset criticality refers to how important a system or resource is to an organization's operations. Example:
Unauthorized access to a **domain controller** → Critical alert.

Asset	Priority Impact
Domain Controller	Very High
Production Database	Very High
Employee Laptop	Medium
Test VM	Low

Exploit Likelihood

Exploit likelihood measures the probability that attackers can successfully exploit a vulnerability.
Factors affecting exploit likelihood:

- Public exploit availability
- Active attacks in the wild
- Known vulnerabilities (CVEs)

Example: CVE-2021-44228
This vulnerability had:

- Public exploit
- Internet-wide scanning
- High CVSS score

SOC priority: **Critical**

Business Impact

Business impact refers to the potential damage an incident could cause to an organization's operations, finances, reputation, or legal compliance.
Example: Data leak from **customer database** → Critical priority.

CVSS (Common Vulnerability Scoring System)

The **Common Vulnerability Scoring System (CVSS)** is a standardized framework used to measure the severity of security vulnerabilities using numerical scores.
Common Vulnerability Scoring System

Score	Severity
0.0 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10	Critical

Log4Shell CVSS score = **9.8 (Critical)**

CVSS Metric Types

Base Metrics
Measure the inherent characteristics of a vulnerability.
Factors include:

- Attack Vector
- Attack Complexity
- Privileges Required
- User Interaction
- CIA Impact

Temporal Metrics
These metrics change over time based on:
- Exploit availability
- Patch availability
- Threat intelligence

Example: When an exploit becomes public → risk increases.

Environmental Metrics
These adjust scores based on the organization's environment.
Example: Same vulnerability:
- Low risk on **test system**
- High risk on **production server**

SOC Risk Scoring Example
Example using: Splunk Enterprise Security

Event	Risk Score
Malware detection	80
Suspicious login	40
PowerShell abuse	60

Total risk score: 80 + 40 + 60 = 180

2. Incident Classification
Incident Classification is the process of categorizing security incidents based on their type, behavior, and impact, allowing SOC analysts to organize alerts, prioritize responses, and follow appropriate response procedures.
In a SOC environment, analysts investigate different types of incidents such as:
- Malware infections
- Phishing attacks
- Insider threats
- Data exfiltration
- DDoS attacks

Classifying incidents helps analysts:
- Understand the nature of the attack
- Assign proper response procedures
- Track attack patterns
- Improve threat intelligence

Without classification, incidents become difficult to manage and investigate.

Core Incident Categories

Malware

Malware incidents involve malicious software designed to damage systems, steal data, or gain unauthorized access. Examples of malware:

- Trojans
- Ransomware
- Spyware
- Rootkits

Example attack: Ransomware encrypting files on a server.

User downloads infected file → malware executes → system compromised

---

Phishing

Phishing is a social engineering attack where attackers trick users into revealing sensitive information such as passwords or financial details. Example phishing indicators:

- Suspicious email links
- Fake login pages
- Urgent requests for credentials

Phishing email → user clicks link → fake login page → credentials stolen

---

Distributed Denial of Service (DDoS)

A DDoS attack occurs when attackers flood a system or network with excessive traffic to make services unavailable. Impact:

- Service downtime
- Business disruption

Botnet sends millions of requests → server overload → website crash

---

Insider Threat

An insider threat occurs when an employee or trusted user misuses their authorized access to harm the organization. Examples:

- Data theft by employee
- Unauthorized data sharing
- Privilege misuse

Employee copies confidential data to personal USB

Data Exfiltration

Data exfiltration is the unauthorized transfer of sensitive data outside an organization. Example targets:

- Customer databases
- Financial records
- Intellectual property

Compromised system → attacker compresses files → uploads to external server

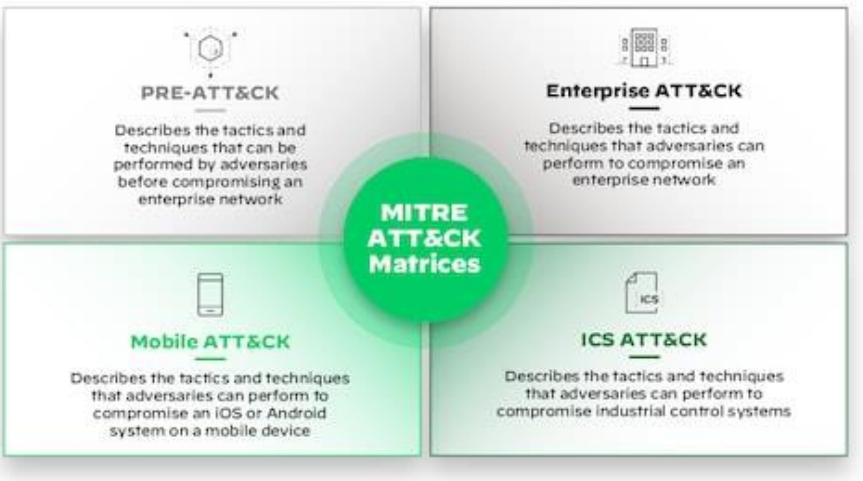
Incident Classification Frameworks

SOC analysts use standardized frameworks to classify incidents.

MITRE ATT&CK Framework

MITRE ATT&CK is a knowledge base of attacker tactics and techniques based on real-world cyber attacks. It helps analysts map incidents to attacker behavior. Example technique:

Technique ID	Attack Type
T1566	Phishing



ENISA Incident Taxonomy

European Union Agency for Cybersecurity

ENISA provides a standardized classification system for cybersecurity incidents across organizations. Categories include:

- Malware
- Intrusion
- Data breach
- Fraud
- Service disruption

Purpose:

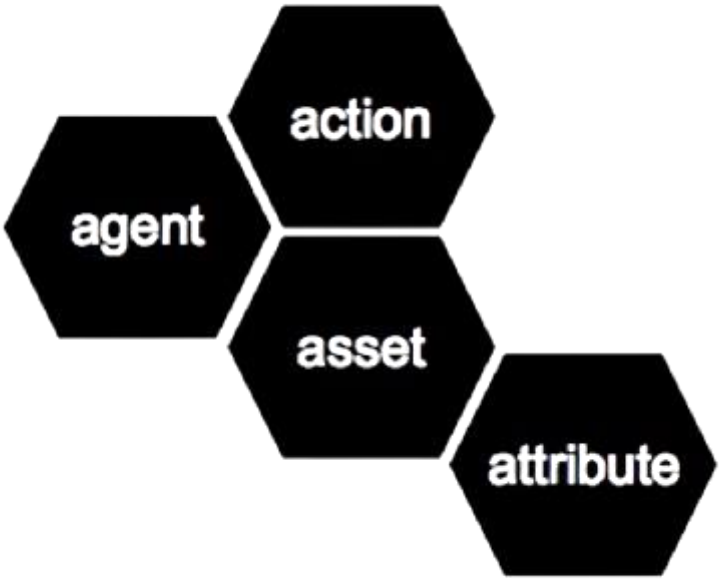
- Consistent incident reporting
- Cross-organization collaboration

VERIS Framework

VERIS is a framework used to record and analyze security incidents in a structured format.
It categorizes incidents into:

- Actor
- Action
- Asset
- Attribute

Component	Example
Actor	External attacker
Action	Phishing
Asset	Email account
Attribute	Credential theft



Contextual Metadata in Incident Classification

Metadata is additional contextual information used to enrich an incident investigation. It helps analysts understand the full scope of the incident.

Timestamp

Indicates when the event occurred. Example: 2026-03-05 10:21:33
Helps determine attack timeline.

Source IP Address

Identifies the origin of the activity. Example: 185.220.x.x
Used for:

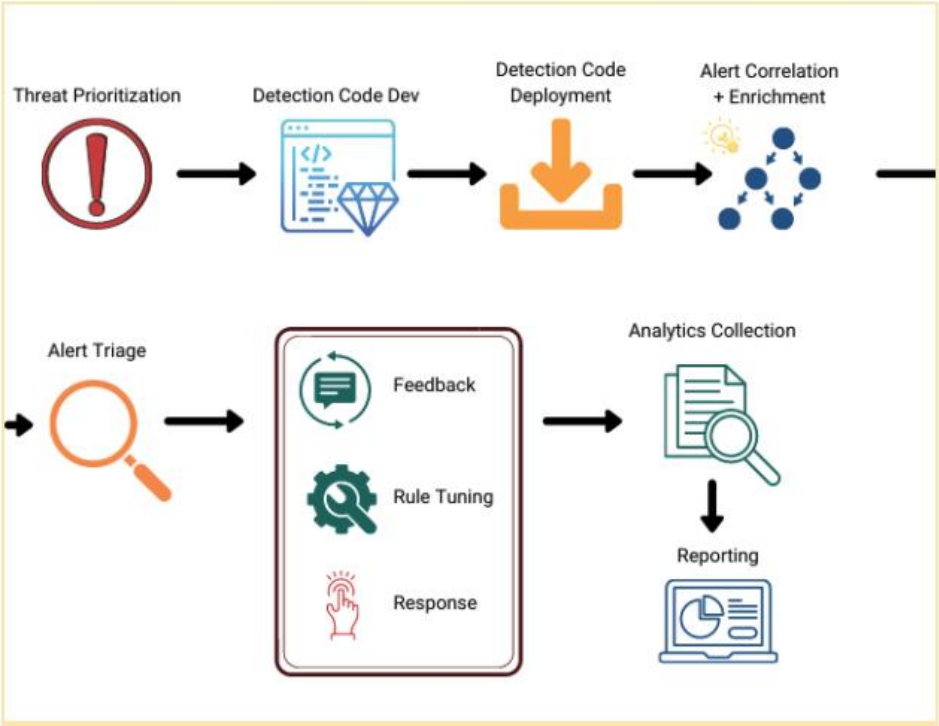
- Threat intelligence lookup
- Geolocation analysis

Indicators of compromise (IOCs)
IOCs are forensic artifacts indicating potential compromise.

IOC Type	Example
IP address	Malicious C2 server
File hash	Malware sample
Domain	Phishing website

SOC Classification Workflow

Alert Generated
↓
Analyze alert details
↓
Identify attack type
↓
Map to MITRE ATT&CK technique
↓
Add metadata (IP, hash, host)
↓
Classify incident



3. Basic Incident Response

Incident Response (IR) is the structured process used by security teams to detect, investigate, contain, eradicate, and recover from cybersecurity incidents while minimizing damage to systems, data, and business operations.
In a **Security Operations Center (SOC)**, incidents such as malware infections, unauthorized access, or data breaches require a systematic response process.

Without a structured response:

- attacks may spread
- evidence may be lost
- systems may remain compromised

Incident response ensures that organizations:

- respond quickly
- limit attacker activity
- restore operations
- improve security defenses

Most organizations follow the framework defined in: NIST SP 800-61
This framework defines six phases of incident response.

Incident Response Lifecycle

Preparation

Preparation is the phase where organizations build the capabilities, tools, and procedures required to handle security incidents effectively. This phase happens before any incident occurs.

Preparation includes:

- Creating incident response playbooks
- Deploying security tools
- Training SOC analysts
- Establishing communication procedures

Example SIEM: Elastic Security

Examples of preparation tools:

- SIEM
- Endpoint Detection & Response
- Threat intelligence feeds
- Incident response playbooks

Identification

Identification is the process of detecting and confirming that a security incident has occurred. This usually begins with an alert generated by security monitoring tools.
Key Activities**:** SOC analysts perform:

- Alert triage
- Log analysis
- Threat intelligence verification
- Incident classification

Example alert: Alert: Suspicious PowerShell execution
Host: Finance-server User: admin
The analyst must determine:

- Is it malicious?
- Is it a false positive?

Investigation Tools
Common SOC investigation tools include:
- SIEM platforms
- Endpoint detection tools
- Network monitoring systems

Example: Splunk Enterprise Security

Containment
Containment is the process of limiting the spread and impact of an attack to prevent further damage. Once an incident is confirmed, the SOC team takes action to stop the attacker.
Types of Containment
Short-Term Containment
Immediate actions taken to stop the attack. Examples:
- isolate infected host
- block malicious IP
- disable compromised account

Example: Host HR-PC01 infected with malware → isolate device from network
Long-Term Containment
Temporary fixes that allow business operations while investigation continues. Examples:
- patch vulnerable systems
- restrict network access
- apply firewall rules

Eradication
Eradication is the process of removing the root cause of the incident from the environment. After containment, the SOC team removes the attacker's access and malicious artifacts.
Examples:
- remove malware
- delete malicious files
- revoke compromised credentials
- close vulnerabilities

Example: Delete malware file and remove malicious registry keys.
Malware Removal Example
Steps may include:
- terminate malicious process
- delete executable file
- clean persistence mechanisms

Persistence examples:
- startup folder
- registry run keys
- scheduled tasks

Recovery
Recovery is the process of restoring affected systems to normal operation while ensuring they are secure.
Recovery may include:
- restoring systems from backups
- rebuilding compromised machines

- validating system integrity
- monitoring for reinfection

Example: Restore compromised server from clean backup.
Before reconnecting systems, analysts verify:

- no malicious processes remain
- vulnerabilities are patched

Lessons Learned

Lessons Learned is the phase where organizations analyze the incident to improve future detection and response capabilities. This phase occurs **after the incident is resolved**.
SOC teams conduct:

- post-incident review meetings
- root cause analysis
- security control improvements
- detection rule updates

Example: Incident: Phishing attack compromised employee credentials. Lessons learned:

- implement phishing awareness training
- add email security rules
- strengthen MFA policies